Week 4 - AWS Config (rules managed / custom, conformance packs, aggregators, remediation via SSM)

DOP-C02 Domain 2 (and Domain 6 for compliance). Typical questions:

1. **Record and audit** how resources are configured over time = **Config history** (+ CloudTrail for who).
2. **Detect** non-compliant resources (unencrypted buckets, open SSH, missing tags) = **Config rules**.
3. **Auto-fix** non-compliant resources = **Config remediation with SSM Automation**.
4. Deploy a **standard rule set** (PCI, CIS) to **every account** = **(organization) conformance packs**.
5. Compliance **across all accounts and Regions in one place** = **aggregator**.

The big idea: **Config = configuration recorder + compliance engine**. It records **what every resource looks like over time** and **evaluates it against rules**. It is **detective**; add **SSM Automation** to fix and **SCPs / proactive controls** to prevent.

Part 1 - Setup and what Config records

Component	Detail
Configuration recorder	Records **configuration items (CIs)** for **all supported types** or **selected types** (with exclusions); **one per account per Region**; **regional** - enable in every Region you use
Recording frequency	**Continuous** or **daily / periodic** per resource type (daily for high-churn types = **lower cost**)
Global resources (IAM)	**Record in one Region only** (avoid duplicates and cost)
Delivery channel	**S3 bucket** (history files about every 6 hours, snapshots) + optional **SNS topic** (all notifications, noisy)
IAM	Service-linked role `AWSServiceRoleForConfig` (or custom)
Retention	Configurable (default **7 years**, minimum 30 days)
Cost	Per **configuration item recorded** + per **rule evaluation** (+ conformance pack evaluations)

Feature	Use
Configuration item	Point-in-time snapshot: attributes, **relationships** (EC2 - ENI - SG - VPC), tags, **related CloudTrail event IDs**
Timeline / history	"**What did this SG look like last Tuesday?**"
Snapshot	Current config of all resources to S3
Advanced queries	**SQL-like SELECT** over **current** config, one account or **an aggregator**
Relationships	Find resources affected by a change
Custom resource types	Third-party / on-prem via `PutResourceConfig`

```
SELECT resourceId WHERE resourceType = 'AWS::EC2::Instance'
  AND configuration.instanceType = 't2.micro'
```

	AWS Config	CloudTrail
Answers	**What** the resource looks like, how it changed, **compliant?**	**Who** called **which API**, when, from where
Data	CIs, history, compliance	API events
Together	A CI links to the CloudTrail event that caused it	

Part 2 - Config rules

Results: **COMPLIANT / NON_COMPLIANT / NOT_APPLICABLE / INSUFFICIENT_DATA**. **Rules are detective - they don't block changes** (except proactive evaluation).

Rule types

Type	How	When
AWS managed	Predefined, configurable **parameters**	**First choice**
Custom Lambda	**Your Lambda** gets the CI or periodic trigger, calls `PutEvaluations`; **Config needs invoke permission** (resource policy for `config.amazonaws.com`)	Complex logic, external data (CMDB)
Custom policy (Guard)	**CloudFormation Guard DSL**, **no Lambda**	Simple attribute checks without code
Service-linked	Created by **Security Hub**, **Control Tower**, Firewall Manager; **can't edit / delete**	

Common managed rules

Area	Rules
S3	`s3-bucket-server-side-encryption-enabled`, `s3-bucket-public-read-prohibited`, `s3-bucket-versioning-enabled`, `s3-bucket-logging-enabled`, `s3-bucket-ssl-requests-only`
EC2 / EBS	`encrypted-volumes`, `ec2-ebs-encryption-by-default`, `approved-amis-by-id` / `-by-tag`, `desired-instance-type`, `ec2-imdsv2-check`, `ec2-instance-managed-by-systems-manager`, `ec2-managedinstance-patch-compliance-status-check`
Network	`restricted-ssh`, `restricted-common-ports`, `vpc-flow-logs-enabled`, `vpc-default-security-group-closed`
IAM	`iam-password-policy`, `root-account-mfa-enabled`, `iam-user-mfa-enabled`, `access-keys-rotated`, `iam-policy-no-statements-with-admin-access`
Logging	`cloudtrail-enabled`, `multi-region-cloudtrail-enabled`, `cloud-trail-log-file-validation-enabled`
Databases	`rds-multi-az-support`, `rds-storage-encrypted`, `rds-instance-public-access-check`, `dynamodb-pitr-enabled`
Tags / other	`required-tags` (up to 6 keys), `cloudformation-stack-drift-detection-check`, `lambda-function-public-access-prohibited`, `acm-certificate-expiration-check`

Triggers and evaluation modes

Trigger	Meaning
Configuration changes	Runs when a matching resource changes; **scope** by **resource types**, **tag**, or **resource ID**
Periodic	Every **1, 3, 6, 12 or 24 hours** (`access-keys-rotated`, `cloudtrail-enabled`)
Both	Some rules support both

Mode	Meaning
Detective (default)	Evaluates **recorded** resources after they change
Proactive	Evaluates a configuration **before deployment**: `StartResourceEvaluation` (pipelines) or **CloudFormation Hooks / Control Tower proactive controls**; only **some managed rules**

- Re-evaluate on demand: `StartConfigRulesEvaluation`.
- Custom results: `PutEvaluations` (Lambda), `PutExternalEvaluation` (process checks).

Part 3 - Remediation via SSM Automation

Attach an **SSM Automation document** to a rule; fix **manually** (Remediate button) or **automatically**.

Setting	Detail
Remediation action	SSM Automation document (AWS-owned `AWSConfigRemediation-*`, `AWS-*`, or custom)
Manual vs automatic	Manual: select resources and remediate; **automatic**: runs when NON_COMPLIANT
Parameters	Static values + `RESOURCE_ID` (non-compliant resource ID passed into a parameter like `BucketName`)
`AutomationAssumeRole`	Role the runbook uses; **trust** `ssm.amazonaws.com` + fix permissions - **#1 cause of remediation failures**
Retries	**Maximum automatic attempts** + **retry window (seconds)**
Rate control	Concurrency / error percentage
Exceptions	**Remediation exceptions** exclude specific resources

Problem	Runbook
Bucket without encryption	`AWSConfigRemediation-EnableS3BucketEncryption` / `AWS-EnableS3BucketEncryption`
Public bucket	`AWSConfigRemediation-ConfigureS3BucketPublicAccessBlock`, `AWS-DisableS3BucketPublicReadWrite`
SSH / RDP open to 0.0.0.0/0	`AWSConfigRemediation-RemoveUnrestrictedSourceIngressRules`, `AWS-DisablePublicAccessForSecurityGroup`
CloudTrail log validation	`AWSConfigRemediation-EnableCloudTrailLogFileValidation`
EBS encryption by default	`AWSConfigRemediation-EnableEbsEncryptionByDefault`
VPC flow logs missing	`AWS-EnableVPCFlowLogs`
Unused credentials	`AWSConfigRemediation-RevokeUnusedIAMUserCredentials`
Just notify	`AWS-PublishSNSNotification`
Stop / terminate instance	`AWS-StopEC2Instance`, `AWS-TerminateEC2Instance`

Event-driven alternative and notifications

- **EventBridge** on `Config Rules Compliance Change` (`NON_COMPLIANT`) -> Lambda / SSM Automation / Step Functions / SNS for custom workflows, ticketing, cross-account handling.
- The **delivery channel SNS topic sends every Config event** (noisy); "**notify only on non-compliance**" = **EventBridge filtered pattern**.

```
{ "source": ["aws.config"],
  "detail-type": ["Config Rules Compliance Change"],
  "detail": { "configRuleName": ["restricted-ssh"],
              "newEvaluationResult": { "complianceType": ["NON_COMPLIANT"] } } }
```

Part 4 - Conformance packs

A **collection of Config rules + remediation actions** in **one YAML template**, deployed and managed **as a single unit**.

```
Parameters:
  RemediationRoleArn: { Type: String }
Resources:
  S3EncryptionRule:
    Type: AWS::Config::ConfigRule
    Properties:
      ConfigRuleName: s3-bucket-server-side-encryption-enabled
      Source: { Owner: AWS, SourceIdentifier: S3_BUCKET_SERVER_SIDE_ENCRYPTION_ENABLED }
  S3EncryptionRemediation:
    Type: AWS::Config::RemediationConfiguration
    Properties:
      ConfigRuleName: s3-bucket-server-side-encryption-enabled
      TargetType: SSM_DOCUMENT
      TargetId: AWSConfigRemediation-EnableS3BucketEncryption
      Automatic: true
      MaximumAutomaticAttempts: 3
      RetryAttemptSeconds: 60
      Parameters:
        BucketName: { ResourceValue: { Value: RESOURCE_ID } }
        AutomationAssumeRole: { StaticValue: { Values: [ !Ref RemediationRoleArn ] } }
```

Feature	Detail
Sample templates	**Operational Best Practices for** PCI DSS, HIPAA, **CIS AWS Foundations**, NIST 800-53, Well-Architected, FedRAMP
Content	Managed rules, **custom rules** (Lambda / Guard), **remediation configurations**, parameters
Deploy	One account + Region (console, CLI, `AWS::Config::ConformancePack`) or **organization conformance packs** (`PutOrganizationConformancePack`) from the **management account or Config delegated admin**
Compliance score	% compliant rule-resource combinations
Members	Can't modify / delete rules from an **organization** pack
Prerequisite	**Config recorder running** in each target account / Region

Organization rules and delegated admin

- `PutOrganizationConfigRule` deploys **individual rules** to all members (members can't change them).
- **Organization conformance pack** = bundle of rules + remediation (preferred for frameworks).
- **Config delegated admin** (Security Tooling / Audit) for `config.amazonaws.com` and `config-multiaccountsetup.amazonaws.com` - manage org rules, packs, aggregators **without the management account**.

Part 5 - Aggregators

Collect **configuration and compliance data** from **multiple accounts and Regions** into **one aggregator account** - a **central read-only view**.

Source type	How	Notes
Individual accounts	List account IDs + Regions	**Each source account must authorize** (`PutAggregationAuthorization`)
AWS Organization	Whole org + Regions	**No per-account authorization**; IAM role (`AWSConfigRoleForOrganizations`), trusted access; from **management account or Config delegated admin**; **new accounts included automatically**

- **Read-only**: it **doesn't deploy rules, doesn't remediate, doesn't change** sources - use **org rules / conformance packs** to deploy.
- **Config must be enabled** in source accounts / Regions.
- Shows compliance by rule / account / Region, inventory, **advanced queries across the org**.
- Typically in the **Audit / Security Tooling account** (Control Tower puts it in **Audit**).

Part 6 - Integrations and choosing controls

Service	Relationship
Security Hub	Controls (CIS, FSBP) are **service-linked Config rules** - **Config must be enabled**
Control Tower	**Detective controls = Config rules**; Config in every governed account; **aggregator in Audit**
Firewall Manager	**Requires Config**
Systems Manager	**Remediation runbooks**; Inventory as `AWS::SSM::ManagedInstanceInventory`; patch compliance rule
CloudFormation	`cloudformation-stack-drift-detection-check`; proactive via **Hooks**; `AWS::Config::ConfigRule`, `RemediationConfiguration`, `ConformancePack`, `OrganizationConformancePack`, `ConfigurationAggregator`
Audit Manager	Config evaluations as **evidence**
EventBridge	`Config Rules Compliance Change`, `Config Configuration Item Change`
CloudTrail	CI links to the API event

Requirement	Best choice
Prevent an action	**SCP** / Control Tower preventive control
Block non-compliant CloudFormation resources before creation	**Proactive** (Hooks / `StartResourceEvaluation`)
Detect existing non-compliance	**Config rule** (managed, then Guard, then Lambda)
Auto-fix	**Config remediation with SSM Automation** (or EventBridge -> Lambda)
Standard framework across the org	**Organization conformance pack**
Central view across accounts / Regions	**Aggregator**
"What did it look like?"	**Config timeline**
"Who changed it?"	**CloudTrail**
Notify only on non-compliance	**EventBridge compliance-change rule**

Part 7 - Exam traps

Trap	Truth
Config rules prevent changes	**Detective only**; SCPs or proactive Hooks prevent
One Config setup covers all Regions	**Regional**; enable in each Region
Recording IAM in every Region	**Global resources in one Region**
Config too expensive for high-churn resources	**Daily recording** or **exclusions**
Custom Lambda rule never runs	**Invoke permission** for config.amazonaws.com
Simple custom check without Lambda	**Guard custom policy rule**
Check access-key age daily	**Periodic trigger**
Remediation fails	`AutomationAssumeRole` (trust / permissions) or wrong `RESOURCE_ID` mapping
Exclude one resource from remediation	**Remediation exception**
Delivery channel SNS too noisy	**EventBridge NON_COMPLIANT filter**
Aggregator deploys rules / remediates	**No, read-only**
Aggregator shows no data for an account	**Config not enabled** or **authorization missing**
New accounts in the aggregator automatically	**Organization-based aggregator**
PCI rule set in all accounts	**Organization conformance pack**
Members delete org-deployed rules	**Can't**
Manage Config org-wide without management account	**Config delegated admin**
SG state before the incident	**Config timeline**
Who opened port 22	**CloudTrail**
All t2 instances in all accounts	**Advanced query on the aggregator**
Security Hub shows no findings	**Config not enabled**
Check config before deploy	**Proactive evaluation** / Hooks
Required tags	`required-tags` (detect), SCP `aws:RequestTag` (prevent)
Approved AMIs only	`approved-amis-by-id` / `-by-tag` (detect), SCP / Image Builder (prevent / build)

Part 8 - Hands-on lab (about 60 to 75 minutes, low cost)

Lab 1 - Turn on Config

1. Config -> **Set up**: all resource types, **global resources only in this Region**, continuous, new S3 bucket, service-linked role.
2. Change a security group; Resources -> SG -> **Resource timeline** shows the change and the **CloudTrail event**.
3. **Advanced query**: `SELECT resourceId, resourceType WHERE resourceType = 'AWS::EC2::SecurityGroup'`.

Lab 2 - Managed rules

1. Add `restricted-ssh`, `s3-bucket-versioning-enabled` (S3 encrypts by default now, so versioning gives guaranteed findings) and `required-tags` (`tag1Key=CostCenter`).
2. Create an SG with **22 open to 0.0.0.0/0** and an untagged bucket: **NON_COMPLIANT**; use **Re-evaluate**.

Lab 3 - Automatic remediation with SSM

1. Role `ConfigRemediationRole`: trust `ssm.amazonaws.com`; `ec2:RevokeSecurityGroupIngress`, `ec2:DescribeSecurityGroups` (+ `s3:PutBucketVersioning` for S3 tests).
2. `restricted-ssh` -> **Manage remediation**: **automatic**, `AWS-DisablePublicAccessForSecurityGroup`, `GroupId` = **RESOURCE_ID**, `AutomationAssumeRole` = role ARN, 3 attempts, 60 seconds.
3. Open SSH again: NON_COMPLIANT -> **SSM Automation execution** -> **COMPLIANT**.
4. Remove the role permission and repeat: remediation **fails** (execution details). Fix it.

Lab 4 - Custom rules

1. **Guard custom policy rule** `ec2-must-be-t3`, scope `AWS::EC2::Instance`:

```
rule check_type { configuration.instanceType == /^t3\./ }
```

2. Launch a t2.micro: NON_COMPLIANT.
3. Optional **Lambda custom rule** from the blueprint with `lambda add-permission --principal config.amazonaws.com`.

Lab 5 - Notify only on non-compliance

EventBridge rule with the Part 3 pattern -> SNS email; trigger again and receive one focused email.

Lab 6 - Conformance pack and aggregator

1. **Deploy** the sample "Operational Best Practices for CIS AWS Foundations" (or the small YAML above); watch the **compliance score**.
2. **Aggregator**: this account + 2 Regions (individual); org aggregator from management / delegated admin; run an **advanced query against the aggregator**.

Cleanup: delete pack, rules, remediation, aggregator, EventBridge rule, test resources; **stop the recorder** (and delivery channel) to stop CI charges; empty and delete the bucket.

Part 9 - Check yourself

Questions

1. What does the recorder record, and why is Config regional?
2. Avoid duplicate IAM CIs and reduce cost for high-churn resources?
3. Config vs CloudTrail - "what did it look like?" vs "who did it?"
4. The rule options, and when Guard vs Lambda?
5. A custom Lambda rule never evaluates - likely cause?
6. Change vs periodic triggers - example of a periodic rule?
7. Detective vs proactive - how to check config before deployment?
8. Automatically fix SGs open to 0.0.0.0/0 on port 22?
9. Automatic remediation keeps failing - check first?
10. Exclude one resource from remediation?
11. Notify only when a specific rule becomes NON_COMPLIANT?
12. What is a conformance pack, and how to deploy to all accounts?
13. What an aggregator does and doesn't do; individual vs organization source?
14. Aggregator shows nothing for one account - two causes?
15. Security Hub shows no control findings in a new account - why?

Answers

1. **Configuration items** for all / selected types; **enable in each Region**.
2. **Global resources in one Region**; **daily recording / exclusions**.
3. **Config** = configuration and history; **CloudTrail** = who called which API.
4. **Managed**, **custom Lambda**, **custom Guard**; Guard for simple checks without code, Lambda for complex logic / external data.
5. Config lacks **invoke permission** (resource policy for config.amazonaws.com).
6. Change = when matching resources change (scope type / tag / ID); periodic = 1 to 24 hours, e.g. `access-keys-rotated`.
7. Detective = recorded resources; proactive = `StartResourceEvaluation` or **CloudFormation Hooks**.
8. `restricted-ssh` + **automatic remediation** `AWS-DisablePublicAccessForSecurityGroup` (`GroupId` = RESOURCE_ID) + **AutomationAssumeRole**.
9. **AutomationAssumeRole** (trust ssm.amazonaws.com + permissions), then parameter mapping and execution logs.
10. **Remediation exception** (or rule scope by tag / ID).
11. **EventBridge** `Config Rules Compliance Change` filtered by rule + NON_COMPLIANT -> SNS.
12. YAML bundle of rules + remediation as one unit; **organization conformance pack** from management / **Config delegated admin**; recorder required.
13. **Read-only** central view + advanced queries; doesn't deploy / remediate; individual needs **authorization**, organization needs none and **includes new accounts**.
14. **Config not enabled** there, or **authorization missing**.
15. **Config not enabled** - Security Hub controls are service-linked Config rules.

Quick memory summary

- **Config** = **regional** recorder of **CIs** (history, relationships, CloudTrail links) + **compliance rules**; S3 delivery (+ SNS); global resources in one Region; daily recording / exclusions; **advanced queries**.
- **Rules**: **managed** / **custom Lambda** (`PutEvaluations`, invoke permission) / **custom Guard** / service-linked; **change** or **periodic** triggers; **detective**, **proactive** via `StartResourceEvaluation` / Hooks; **don't prevent**.
- **Remediation**: **SSM Automation**, manual or **automatic**, `RESOURCE_ID`, **AutomationAssumeRole**, retries, exceptions; **EventBridge compliance change** for custom / filtered alerts.
- **Conformance packs**: YAML rules + remediation (PCI, CIS, NIST), score; **org packs / org rules** from management or **Config delegated admin**; members can't change.
- **Aggregators**: **read-only** multi-account / Region view (individual = authorization; **org** = automatic new accounts); usually in **Audit**.